

README - KIT COMPLETO ENCUESTA CIBERSEGURIDAD ORGANIZACIONAL

Guía de Inicio Rápido para Implementación

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: Encuesta Integral 7 Módulos | España/EU Compliance

Público: CISOs, Risk Managers, Security Leaders

Idioma: Español

¿QUÉ CONTIENE ESTE KIT?

Kit completo de evaluación de madurez ciberseguridad, compuesto de **7 documentos profesionales** en formato Markdown (.md), listos para descargar e implementar:

Documentos Incluidos

#	Nombre Documento	Propósito	Usuarios Clave	Tamaño
1	Modelo Encuesta Integral	Cuestionario 51 preguntas (7 módulos GQM)	Security Analyst	~30 pp
2	Guía Metodológica Detallada	Cómo administrar, scoring, interpretación	Project Manager	~25 pp
3	Narrativa Explicativa	Antecedentes framework, justificación	CISO, Stakeholders	~20 pp
4	Mapeo Normativo	Preguntas → NIS2/ISO/GDPR alineación	Compliance Officer	~50 pp
5	Plantilla Excel IMC+ROI	Cálculos automáticos madurez & financiero	CFO, Analyst	~25 pp
6	Plantilla PowerPoint	Presentación ejecutiva (13 slides)	CISO, Board	~30 pp
7	README (este documento)	Quick-start, FAQ, troubleshooting	Everyone	~20 pp

Total: ~200 páginas contenido profesional

QUICK START: 5 PASOS

PASO 1: DESCARGA (5 minutos)

Descargar los 7 archivos .md:

```
/tu_proyecto_ciberseguridad/  
├── 1_modelo_encuesta_integral_es.md  
├── 2_guia_metodologica_es.md  
├── 3_narrativa_explicativa_es.md  
├── 4_mapeo_normativo_es.md  
├── 5_plantilla_excel_imc_roi_es.md  
├── 6_plantilla_powerpoint_es.md  
└── 7_README_kit_es.md (este archivo)
```

Formato: UTF-8 Markdown (.md)

Total Size: ~5 MB

Compatibilidad: Windows, Mac, Linux

PASO 2: PREPARACIÓN (30 minutos)

2A. Elige formato de salida:

- ☒ PDF (para distribución/archivado)
- ☒ Word (para edición/customización)
- ☒ Google Docs (para colaboración)
- ☒ Markdown nativo (edición directa)

Recomendación: PDF para documentos 1-4 (referencias); Word para 5-6 (trabajo vivo)

2B. Crea carpeta proyecto:

```
Proyecto_Evaluación_Ciberseguridad_2026/  
├── Documentos/  
│   ├── Modelo_Encuesta.pdf  
│   ├── Guía_Metodológica.pdf  
│   ├── Mapeo_Normativo.pdf  
│   └── Narrativa.pdf  
├── Herramientas/  
│   ├── Excel_Madurez_IMC.xlsx (que crearás)  
│   └── PowerPoint_Reporte.pptx (que crearás)  
├── Datos/  
│   ├── Respuestas_Encuesta.xlsx  
│   └── Validación_Stakeholders.md  
└── Entregas/  
    ├── Reporte_Ejecutivo_Final.pdf  
    └── Roadmap_Implementación.md
```

2C. Asigna responsabilidades:

Rol	Tarea Principal	Entrega
CISO	Sponsor; validación respuestas	Sign-off
Risk Manager	Mapeo normativo; compliance check	Validación
CTO/Técnico	Respuestas técnicas; data sources	Datos brutos
Project Lead	Coordinación; timeline; consolidación	Reporte final
Analyst	Assessment facilitation; scoring	Data entry

PASO 3: ASSESSMENT (3-5 SEMANAS)

Semana 1: Kickoff & Interviews

Participantes clave (obligatorio entrevistar):

1. CISO o Chief Information Security Officer
2. CTO o VP Technology/Infrastructure
3. Risk/Compliance Head
4. Vulnerability Management Lead
5. Security Operations Center (SOC) Lead

Duración: 60-75 minutos por entrevista

Metodología: Usar Modelo Encuesta (Doc #1) como cuestionario estructurado

Facilitador: Preferiblemente externo para objetividad

Guión Facilitador:

Bienvenida (5 min):

"Esta evaluación diagnostica nuestra madurez ciberseguridad versus frameworks internacionales (NIS2, ISO 27001, GDPR). No es auditoría; es roadmap para mejora estratégica."

Contexto (5 min):

Explicar 7 módulos, escala GQM (0-5), alineación regulatoria

Preguntas Detalladas (50 min):

Por cada módulo (7 total):

1. Leer pregunta de encuesta
2. Pedir ejemplos/evidencia actuales
3. Validar contra datos operacionales (SIEM logs, tickets)
4. Asignar score (0-5)
5. Documentar gaps/fortalezas

Cierre (5 min):

"¿Gaps identificados? ¿Prioridades del equipo?"

Confirmar: Resultados consolidados en 2-3 semanas

Semana 2-3: Data Analysis & Consolidation

Actividades:

1. Consolidar respuestas en Excel (Doc #5):
2. Entrar puntajes brutos (0-100 por módulo)
3. Aplicar fórmula IMC automáticamente
4. Generar escenarios ROI
5.
Proyectar trajectory 18 meses
6.
Validación cruzada:
7. Comparar percepciones entre stakeholders
8. Resolver divergencias >15 puntos
9. Triangular vs datos operacionales reales
10.
Document rationale
11.
Análisis normativo (Doc #4):
12. Mapear cada pregunta a regulaciones NIS2/ISO/GDPR
13. Identificar gaps compliance específicos
14. Documentar plazos (crítico: Aug 2026 NIS2)
15. Flag puntos de riesgo regulatorio

Proyectar trajectory 18 meses

Validación cruzada:

Document rationale

Análisis normativo (Doc #4):

Semana 4-5: Reporte & Presentación

16. Customizar PowerPoint (Doc #6):
17. Copiar estructura base (13 slides)
18. Insertar tu data de assessment (IMC, módulos, gaps)
19. Agregar contexto organizacional específico
- 20.

Personalizar presupuesto/ROI escenarios

21.

Ensayar presentación:

22. Mock presentation interno (30 min)
23. Anticipar preguntas (finance, timeline, ROI)
24. Validar números con stakeholders
25. Grabar timing (target: 35-40 min + Q&A)

Personalizar presupuesto/ROI escenarios

Ensayar presentación:

PASO 4: PRESENTACIÓN EJECUTIVA (1-2 SEMANAS)

Audiencia: Board, CEO, CFO, CRO, CISO

Formato: Presencial + virtual option

Duración: 45 minutos (35 min pres + 10 min Q&A)

Secuencia Recomendada:

00:00-03 min: Contexto (NIS2 deadline, regulatory drivers)
03-08 min: IMC Global (39/100, Level 2, gap to target)
08-20 min: 7 módulos detallados (fortalezas + gaps críticos)
20-25 min: Roadmap (4 fases, presupuesto, timeline)
25-30 min: ROI (realistic scenario, payback 10+ months)
30-35 min: Decisiones (5 puntos de aprobación)
35-45 min: Q&A

Materiales:

- PowerPoint presentación (Doc #6)
- Excel dashboard impreso (Doc #5) como handout
- Mapeo normativo impreso (Doc #4) como referencia
- 1-pager ejecutivo (2 páginas) con puntos clave

PASO 5: IMPLEMENTACIÓN (6-18 MESES)

Una vez aprobado por board:

Fase 1 (Month 1): Gobernanza foundation

- CISO reporting to CEO

- Steering committee created
- Budget allocation approved

Fase 2 (Months 2-4): Core technical capabilities

- SIEM deployment
- Automated vulnerability management
- MFA universal rollout
- IR/SOAR implementation

Fase 3 (Months 5-6): Compliance validation

- NIS2 audit readiness
- Final gaps closure
- Regulatory sign-off

Fase 4 (Months 7-18): Optimization & continuous improvement

- AI/ML threat detection
- Advanced automation
- Culture embedding

Tracking monthly: Usar Excel dashboard (Doc #5) para progress updates

CÓMO USAR CADA DOCUMENTO

Doc #1: Modelo Encuesta Integral

Cuándo usarlo:

- Semana 1: Cuestionario durante interviews (cuestionario estructurado)
- Referencia: Para aclaraciones preguntas
- Post-assessment: Validación respuestas

Cómo usarlo:

1. Imprime o comparte digitalmente (Google Form opcional)
2. Por cada pregunta (51 total en 7 módulos):
 - Lee pregunta textualmente
 - Pide ejemplos/evidencia
 - Asigna score (0-5 o %)
 - Documenta notas
3. Recolecta durante 5 interviews
4. Traslada respuestas a Excel para análisis

Preguntas típicas:

- "¿Cuál es la diferencia entre Nivel 2 y 3?"
 - Respuesta: Nivel 2 = Repetible (inconsistent); Nivel 3 = Defined (formal process)

Doc #2: Guía Metodológica

Cuándo usarlo:

- Pre-assessment: Entrenamiento facilitador
- Durante assessment: Referencia scoring criteria
- Post-assessment: Interpretación resultados

Cómo usarlo:

1. Facilitador lee Guía completamente (1-2 horas)
2. Entiende escala GQM 0-5 y matapelículas
3. Estudia ejemplos scoring por módulo
4. Durante interviews: Consulta guía para criterios
5. Post-interviews: Usa para validación scoring

Preguntas típicas:

- "¿Por qué respondieron 3 en Gobernanza?"
 - Respuesta: Ver Guía scoring criteria; CISO reports COO pero not CEO (Nivel 2-3 threshold)

Doc #3: Narrativa Explicativa

Cuándo usarlo:

- Pre-kick: Stakeholder briefing (contexto framework)
- Executive education: Explicar por qué este assessment importa
- Cierre: Validar alineación con estrategia negocio

Cómo usarlo:

1. CISO comparte con board/C-level (ejecutivo summary)
2. 10-15 min reading time
3. Facilita discussion: "Does framework align with our strategic priorities?"
4. Valida que hay buy-in para investment

Preguntas típicas:

- "¿Por qué 7 módulos específicamente?"
 - Respuesta: Cobertura holística (gobernanza + técnico + cumplimiento + cultura)

Doc #4: Mapeo Normativo

Cuándo usarlo:

- Semana 2-3: Post-assessment validation
- Compliance review: Entender gaps vs NIS2/ISO
- Roadmap planning: Priorizar por deadline

Cómo usarlo:

1. Revisa cada pregunta encuesta
2. Mapea a normativa(s) aplicable(s)
3. Nota plazo cumplimiento

4. Identifica gaps regulatorios
5. Prioriza remediation por deadline (urgency)

Preguntas típicas:

- "¿Cuál es plazo NIS2?"
 - Respuesta: Aug 31, 2026 (11 meses); Art.17 requiere governance formal
- "¿Qué pasa si no cumplimos?"
 - Respuesta: €50M penalty o 10% annual turnover; reputational damage

Doc #5: Plantilla Excel

Cuándo usarlo:

- Semana 3: Post-responses entrada data
- Análisis financiero: Justificación presupuesto
- Monthly tracking: Progress toward targets

Cómo usarlo:

1. Descargar template Excel (vacío)
2. Hoja "RawData": Entrar 51 respuestas preguntas
 - Fuentes: SIEM logs, ticketing systems, audit reports, surveys
3. Hoja "Dashboard": Fórmulas calculan automáticamente
 - IMC global (0-100)
 - ROI escenarios (conservative/realistic/optimistic)
 - Payback period (meses)
4. Hoja "Trajectory": Proyectar 18-month improvement
5. Monthly updates: Refresh data for trending

Fórmulas clave:

$$\text{IMC} = (\text{Avg_Módulos} \times 0.50) + (\text{Compliance\%} \times 0.30) + (\text{Implementation\%} \times 0.20)$$
$$\text{ROI\%} = (\text{Benefits} - \text{€2.1M}) / \text{€2.1M}$$
$$\text{Payback} = 12 / (\text{Annual_Benefit} / 12 / \text{€2.1M})$$

Preguntas típicas:

- "¿Cómo se calcula IMC?"
 - Respuesta: Fórmula ponderada: 50% operacional + 30% compliance + 20% deployment

Doc #6: Plantilla PowerPoint

Cuándo usarlo:

- Semana 4-5: Board presentation preparation
- Executive updates: Quarterly steering committee reviews
- Advocacy: Obtain funding approval

Cómo usarlo:

1. Descargar template (vacío)

2. Customizar para tu organización:

- Slide 3: Tu IMC (39/100) vs benchmark
- Slide 4: Tu 7 módulos scores + status
- Slide 7: Tu 3 gaps críticos (específico al assessment)
- Slide 9: Tu roadmap (fases, presupuesto, timeline)
- Slide 10: Tu ROI escenarios (conservative/realistic/optimistic)
- Slide 11: Tu risk analysis (do-nothing vs invest)

3. Agregar branding corporativo

4. Ensayar presentación (target: 35-40 min)

5. Recolectar aprobaciones (5 decisiones)

Recomendación: No leas slides; usa como visual support mientras hablas

Doc #7: README (este documento)

Propósito: Guía práctica de implementación + FAQ

Secciones principales:

- Overview: Qué contiene kit
- Quick start: 5 pasos
- Document guide: Cómo usar cada doc
- FAQ: 15+ preguntas comunes
- Troubleshooting: Problemas comunes & soluciones
- Timeline: Calendario recomendado

? FAQ (15 PREGUNTAS FRECUENTES)

F: ¿Cuánto tiempo toma completar encuesta + assessment?

R: 3-5 semanas total, depending on organizational complexity:

- Week 1: 5 interviews (60-75 min each)
- Weeks 2-3: Data analysis, validation, consolidation
- Weeks 4-5: Report generation, board presentation prep

Total effort: ~80-120 horas (consultant + internal team)

F: ¿Necesitamos consultant externo o puede ser completamente interno?

R: Recomendación: **Híbrida approach**

- Facilitator externo: Credibilidad, objectivity (60% value add)
- Internal team: Operacional knowledge, buy-in (40% value)

Costo: ~€10-15K (30 days × €400/day) = 1% of total investment

ROI: Worth it for credibility, though not strictly required

F: ¿Qué pasa si nuestros scores son muy bajos (20-30)?

R: Normal. Majority organizations en Level 1-2 (10-50 IMC).

Interpretar como:

- ✓ Diagnosis activa (not crisis assessment)
- ✓ Clear roadmap para improvement
- ✓ Business case well-defined

Comunicar al board: "Assessment is baseline; we have clear path to compliance"

F: ¿Qué es IMC y cómo se diferencia de un audit?

R:

- **IMC:** Evaluación estratégica madurez (diagnóstico de salud)
- **Audit:** Validación compliance vs específico estándar

IMC es *anterior* a audit. Ideal timing:

1. IMC assessment Q1 2026 (estrategia)
2. Implementation Q2-Q3 2026 (ejecutar)
3. ISO audit Q4 2026 (validación)

F: ¿Implementamos todos 7 módulos simultáneamente?

R: No. Fases recomendadas:

- **Phase 1 (1 mes):** Gobernanza (prerequisito; €0)
- **Phase 2 (2-3 mes):** Vuln Mgmt + SIEM + Acceso (core; €1.2M)
- **Phase 3 (1-2 mes):** Compliance + Integration (€200K)
- **Phase 4 (6+ mes):** Advanced + Optimization (€500K)

Razón: Gobernanza primero; habilita todo lo demás

F: ¿Cuál es ROI más realista?

R: Realistic scenario:

- Investment: €2.1M Year 1
- Benefits: €3-€3.5M (2 breaches prevented + efficiency)
- Net Year 1: +€900K-€1.4M
- Payback: 7-10 months
- 3-year cumulative: €8-€10M

Rango: Conservative (15%) – Realistic (180%) – Optimistic (280%)

F: ¿Cuál es timeline a NIS2 compliance?

R: 11 meses (August 31, 2026 deadline)

Acción required:

- Q1 2026: Assessment + roadmap (this quarter)
- Q2-Q3 2026: Phase 2 implementation (core capability build-out)
- Q4 2026: Compliance validation + audit

Con acción inmediata ahora: 95%+ achievable by Aug 2026

F: ¿Cómo escalamos a múltiples ubicaciones/divisiones?

R:

1. **Pilot:** 1 ubicación (3-5 semanas)
2. **Template:** Replicate to others; customize por contexto local
3. **Consolidation:** Aggregate scores a nivel portfolio

Timeline: +2-3 semanas por sitio adicional (after pilot)

F: ¿Cómo se integra con ISO 27001 audit?

R: Complementario, no reemplazo:

- IMC: Strategic maturity + compliance alignment (macro)
- ISO 27001: Detailed control framework (micro)

Ideal timing:

1. IMC assessment – roadmap (Q1)
2. ISO pre-audit gap analysis (Q2-Q3)
3. ISO audit (Q4)
4. Implementation (2027)

F: ¿Quiénes son stakeholders críticos para buy-in?

R: 5 roles clave:

1. **CEO:** Budget approval; governance commitment
2. **CFO:** Financial case; ROI justification
3. **CISO:** Technical roadmap; execution accountability
4. **CTO:** Implementation feasibility; resource planning
5. **Board Audit Chair:** Regulatory/compliance oversight

Enganche all 5 en Week 1 kickoff

F: ¿Qué pasa post-assessment?

R: 18-month roadmap ejecución:

Q1 2026: Assessment complete → Board approval
Q2 2026: Phase 1-2 begin → SIEM deployment, MFA rollout
Q3 2026: Phase 2 continuing → Compliance checkpoint 1
Q4 2026: Phase 3 → NIS2 deadline (Aug 31) ✓
2027: Phase 4 → Advanced capabilities (85+ IMC)

Monthly tracking usando Excel dashboard; quarterly board updates

F: ¿Cuáles son riesgos de no actuar?

R: Significativos:

- NIS2 non-compliance: €50M+ penalty or 10% turnover
- Breach probability: 1-2 incidents – €500K-€2M damage
- Operational waste: €200-€300K/year (no strategy)
- Competitive disadvantage: Peers at 70-80% move ahead

Total risk: €3-€10M+ annually

F: ¿Hay alternativas a este framework?

R: Otros frameworks existen:

- NIST Cybersecurity Framework (US-centric)
- CIS Controls v8 (technical focus)
- COBIT 2019 (governance focus)
- ISO 27001 (control framework)

Este kit (GQM + 7 módulos) es **balanced**: combina governance + technical + compliance + culture

Ventaja: Alineado específicamente con regulaciones españolas/EU (NIS2, GDPR, Plan Nacional)

TROUBLESHOOTING

Problema: Stakeholders dan respuestas muy divergentes (>20pp diferencia)

Solución:

1. Facilitar discussion: "¿Por qué diferencia?"
2. Normalizar hacia data: SIEM logs, ticketing systems (truth)
3. Document rationale; not simple average
4. Escalar si divergencia >30pp (possible gaps en comunicación)

Problema: Excel formulas no calculan correctamente

Solución:

1. Verificar formato números (sin €, %, commas)
2. Revisar cell references (formula aún válida?)
3. Cambiar cell format a "Number"
4. Copy-paste formula nuevamente si es necesario
5. Usar Google Sheets (cloud) si Excel issues persisten

Problema: Presupuesto rechazado por Finance

Solución:

1. Reframe como "risk mitigation" (no capex)
2. Emphasize realistic scenario: 10-month payback
3. Anchor vs cost of ONE breach (€500K-€2M)
4. Proponer phased: Phase 1 (€0), Phase 2 (€1.2M) con board approval post-Phase 1
5. Highlight regulatory mandate (NIS2 Aug 2026 deadline)

Problema: NIS2 deadline solo 11 meses away

Solución:

1. Accelerate Phase 1+2: compress 3 meses → 6 weeks
2. Hire temporary resources (contract analysts)
3. Prioritize NIS2-specific gaps (Module 4: Compliance mapeo)
4. Target: 95%+ compliance by Aug 2026; optimization 2027+

Problema: No tenemos SIEM, SBOM tools, o PAM system deployed

Solución:

- Use assessment scores para justify acquisition
- Phase implementation: Pilot first 2-3 meses, then scale
- Leverage existing tools (syslog, file-based logging) interim
- ROI case supports investment (quick payback)



REFERENCIAS & RECURSOS

Documentos Regulatorios

- NIS2 Directive - EU Official Journal
- EU AI Act - EU Official Journal
- Plan Nacional Ciberseguridad - CNCS España
- ISO 27001:2022 - ISO catalogue

Herramientas Recomendadas

- Assessment facilitation: Miro, Mural, virtual whiteboarding
- Data aggregation: Excel, Google Sheets, Airtable
- Survey administration: Google Forms, Qualtrics, Typeform
- Reporting: PowerPoint, Google Slides, Figma
- Project tracking: Jira, Asana, Monday.com

Consultores/Partners

- INCIBE (Spain): NIS2 guidance
- Big 4 firms (KPMG, Deloitte, PwC): Full assessments
- Fortified, CrowdStrike, Darktrace: Specific capabilities
- Local cybersecurity firms: Regional expertise



SOPORTE

Preguntas sobre Contenido

Framework: Revisar Doc #3 (Narrativa Explicativa)

Metodología: Revisar Doc #2 (Guía Metodológica)

Compliance: Revisar Doc #4 (Mapeo Normativo)

Implementación: Revisar este README (FAQ/Troubleshooting)

Preguntas sobre Herramientas

Excel setup: Doc #5 (Plantilla Excel) - Fórmulas predefinidas incluidas

PowerPoint: Doc #6 (Plantilla PowerPoint) - Design templates incluidas

Timeline: Este README (Roadmap sección)

Contacto para Consultoría Avanzada

Para assessment facilitation hands-on:

Email: assessments@ciberseguridad-spain.com

Tel: +34-XXX-XXX-XXXX

Services: Facilitación experta, customización, ejecución roadmap

CHECKLIST ANTES DE EMPEZAR

- ☐ Descargados los 7 documentos .md
- ☐ Creada carpeta proyecto local
- ☐ Identificados 5 stakeholders clave
- ☐ Designado project lead (CISO o equivalente)
- ☐ Reservado calendario: Week 1 interviews, Weeks 2-5 analysis/presentation
- ☐ Comunicado a board: "Assessment iniciando" (set expectations)
- ☐ Preparada sala/conferencia virtual para facilitation
- ☐ Considerado consultant externo (opcional; 1-week turnaround faster)
- ☐ Confirmado acceso a data sources (SIEM, ticketing, audit reports)
- ☐ Alineado con regulador/auditor externo (si aplica)

PRÓXIMOS PASOS INMEDIATOS

Hoy:

- ☐ Revisar este README completamente (20 min)
- ☐ Compartir Doc #3 (Narrativa) con CISO

Mañana:

- ☐ CISO comparte con leadership team
- ☐ Agendar kickoff meeting con 5 stakeholders

Esta Semana:

- ☐ Prepare facilitation materials (Doc #1: Encuesta)
- ☐ Agendar 5 interviews (60-75 min cada)
- ☐ Confirmar facilitador (interno o externo)

Próxima Semana:

- ☐ Ejecutar interviews (todas 5 completadas)
- ☐ Empezar consolidation de datos

Semana 3:

- ☐ Completar análisis (Excel, mapeo normativo)
- ☐ Draftar PowerPoint

Semana 4:

- ☐ Rehearsal interno
- ☐ Finalize presentation

Semana 5:

- [] Board presentation
- [] Collect approvals

Mes 2+:

- [] Implementation roadmap execution
- [] Monthly dashboards (tracking progress)

CONCLUSIÓN

Este kit te proporciona **herramientas profesionales exhaustivas** para:

1.  Diagnosticar madurez ciberseguridad actual
2.  Alinear con regulaciones NIS2/ISO/GDPR
3.  Justificar inversión financiera (ROI cuantificado)
4.  Ejecutar roadmap estructurado (18 meses)
5.  Comunicar a board/ejecutivos (presentación lista)

Valor Total: ~200 páginas de guía profesional + herramientas + templates

Inversión Prep: 3-5 semanas + €10-15K (opcional consultant)

Implementación: 18 meses + €2.1M investment

ROI Esperado: 180% 3-year cumulative (realistic scenario)

¡Buena suerte con tu evaluación de madurez ciberseguridad!

Kit desarrollado: Enero 2026 / Metodología: GQM 7 Módulos / Contexto: España/EU Compliance

FIN DE README